

Risk Scoring Report — vulnerable-invoice-service

Project: com.demo.supplychain:vulnerable-invoice-service:1.0.0 | Scan date: 2026-06-20 | SHA: 61ed8c3140d76e3a19a88954e834d39c9f7635fb | Model: 0.5 * CVE_severity + 0.3 * exposure + 0.2 * business_criticality

Supply-chain callout: Two structural issues elevate the overall risk posture beyond individual CVE scores — a typosquatted dependency coordinate (band elevated to HIGH regardless of CVE score) and an HTTP-only Maven repository susceptible to MITM artifact injection.

Risk Band Summary

Band	Count	Coordinates
CRITICAL	0	—
HIGH	4	log4j-core, log4j-api, jackson-databind, com.fastxml (typosquat)
MEDIUM	2	guava, commons-io
LOW	3	mysql-connector-java, commons-lang3, junit-jupiter

Ranked Remediation Backlog

#	Coordinate	Ver	Band	Risk Score	CVE Sev	Exposure	Biz Crit	Top CVE / Issue	Fix
1	org.apache.logging.log4j:log4j-core	2.14.1	HIGH	7.8	10.0	8.0	2.0	CVE-2021-44228 (10.0)	2.17.1
2	org.apache.logging.log4j:log4j-api	2.14.1	HIGH	7.8	10.0	8.0	2.0	CVE-2021-44228 (10.0)	2.17.1
3	com.fasterxml.jackson.core:jackson-databind	2.9.8	HIGH	7.8	10.0	8.0	2.0	CVE-2019-14379 (9.8)	2.14.0
4	com.fastxml.jackson.core:jackson-databind	2.9.8	HIGH	2.8 *	0.0	8.0	2.0	TYPOSQUATTING — REMOVE	REMOVE
5	com.google.guava:guava	24.1.1-jre	MEDIUM	5.7	6.4	7.0	2.0	CVE-2018-10237 (5.9)	32.0.0-jre
6	commons-io:commons-io	2.4	MEDIUM	4.9	4.8	7.0	2.0	CVE-2021-29425 (4.8)	2.7
7	mysql:mysql-connector-java	8.0.30	LOW	2.8	0.0	8.0	2.0	LICENSE: GPL-2.0	8.0.33
8	org.apache.commons:commons-lang3	3.4	LOW	2.5	0.0	7.0	2.0	Outdated (9 yrs)	3.14.0
9	org.junit.jupiter:junit-jupiter	5.10.2	LOW	1.7	0.0	5.0	1.0	test-scope, outdated	5.12.2

* Band elevated from LOW to HIGH due to supply-chain TYPOSQUATTING flag — weighted score alone does not reflect the artifact-injection risk.

Scoring Methodology

Each dependency is evaluated on three normalized components (0–10 each):

Component	Weight	Formula
CVE Severity	50%	<code>max(CVSS scores) + 0.5 per additional CVE beyond first</code> , capped at 10
Exposure	30%	Direct (+4) or transitive (+2), compile/runtime (+3) or test/provided (+1), multi-module (+2), network/parsing lib (+1), capped at 10
Business Criticality	20%	Auth/security/payment (+5), public API (+3), internal service (+2), build/test (+1), capped at 10

Final: `risk_score = round(0.5 * cve_severity + 0.3 * exposure + 0.2 * business_criticality, 1)`

Bands: CRITICAL ≥ 8.0 | HIGH 6.0–7.9 (or any CRITICAL CVE) | MEDIUM 3.0–5.9 | LOW < 3.0

Component Score Breakdown

Dependency	CVE Severity	Exposure	Business Criticality	Risk Score	Band
log4j-core 2.14.1	10.0 (4 CVEs, density capped)	8.0 (direct + compile + logging lib)	2.0 (internal invoice service)	7.8	HIGH
log4j-api 2.14.1	10.0 (4 CVEs, density capped)	8.0 (direct + compile + logging lib)	2.0 (internal invoice service)	7.8	HIGH
jackson-databind 2.9.8	10.0 (6 CVEs, density capped)	8.0 (direct + compile + parsing lib)	2.0 (default — no import in source)	7.8	HIGH
com.fastxml:jackson-databind 2.9.8	0.0 (no CVEs — unresolvable)	8.0 (direct + compile + parsing lib)	2.0 (default)	2.8	HIGH (typosquat)
guava 24.1.1-jre	6.4 (2 CVEs: 5.9 max + 0.5 bonus)	7.0 (direct + compile)	2.0 (default — no import)	5.7	MEDIUM
commons-io 2.4	4.8 (1 CVE)	7.0 (direct + compile)	2.0 (default — no import)	4.9	MEDIUM
mysql-connector-java 8.0.30	0.0 (no CVEs)	8.0 (direct + compile + network/DB)	2.0 (default)	2.8	LOW
commons-lang3 3.4	0.0 (no CVEs)	7.0 (direct + compile)	2.0 (default — no import)	2.5	LOW
junit-jupiter 5.10.2	0.0 (no CVEs)	5.0 (direct + test scope)	1.0 (test tooling)	1.7	LOW

Priority Recommendations

- P0 — REMOVE** the `typosquatted com.fastxml.jackson.core:jackson-databind:2.9.8` block from `pom.xml`. This is a supply-chain sabotage vector with no legitimate use.
- P0 — UPGRADE** `log4j-core` and `log4j-api` from `2.14.1` to `2.17.1` together. Log4Shell (CVE-2021-44228, CVSS 10.0) is one of the most widely exploited CVEs in history; this change is non-negotiable.
- P0 — REMOVE** the `internal-untrusted-mirror` HTTP repository from the `<repositories>` block.
- P1 — UPGRADE** `jackson-databind` from `2.9.8` to `2.14.0+`. Six CVEs including a CVSS 9.8 unsafe deserialization RCE.
- P1 — UPGRADE** `guava` from `24.1.1-jre` to `32.0.0-jre+`. Review calling code for deprecated `Files.createTempDir()` usage.
- P2 — UPGRADE** `commons-io` from `2.4` to `2.15.0+`. Path-traversal CVE and 11 years of unpatched drift.
- P2 — RESOLVE** `mysql-connector-java` GPL-2.0 license violation. Replace with `com.mysql:mysql-connector-j:8.0.33` or a permissively-licensed JDBC driver.
- P3 — UPGRADE** `commons-lang3` from `3.4` to `3.14.0+` for security maintenance coverage.

Machine-readable source: `depSCAN-risk-report.json` (Stage 2). Ready for Stage 3 Auto-Remediation Skill and Stage 4 PR Validation Agent.